

BẢO VỆ AN TOÀN THÔNG TIN CHO DOANH NGHIỆP

THE FORUM - HỆ THỐNG TRUNG TÂM ANH NGỮ

Trình bày: Lê Thanh Hà

Công ty TNHH The Forum Education Vietnam

Giám đốc điều hành	Nguyễn Hoàng Huy
Ngày thành lập	01/2019
Nguồn vốn	Vốn tư nhân
Sản phẩm/ dịch vụ chính	Dạy IELTS tại Trung tâm + Online
Doanh thu năm 2025	Khoảng 20-50 tỷ
Số lượng máy tính	Khoảng 40-60 máy
Số lao động	Khoảng 70-100 lao động

4+2

Trung tâm Anh Ngữ
THE FORUM

- Mô hình học tiên phong University Lecture
- Nâng band cấp tốc chỉ sau 90 giờ học
- Chuyên đào tạo IELTS/SAT/Tiếng Anh Trẻ Em
- Cam kết chất lượng đầu ra

Đăng ký ngay →

9.0 IELTS

LEAD: FORM / LIVESTREAM

TƯ VẤN & HẸN TEST

TEST ĐẦU VÀO

LỘ TRÌNH & HỌC PHÍ

CAM KẾT & THỦ TỤC

CÁC TÌNH HUỐNG RỦI RO ĐÃ XẢY RA Ở CÔNG TY KHÁC

THE
FORUM

SHE by Hoa Nguyen (SBHN) - Fanpage giả mạo thương hiệu thật

Kẻ gian sao chép Fanpage chính thức:

tên, ảnh, hotline, địa chỉ, bài đăng

→ **chạy ads giá sốc, có tích xanh**

→ **khách chuyển cọc vào STK lạ**

→ **chặn liên lạc**

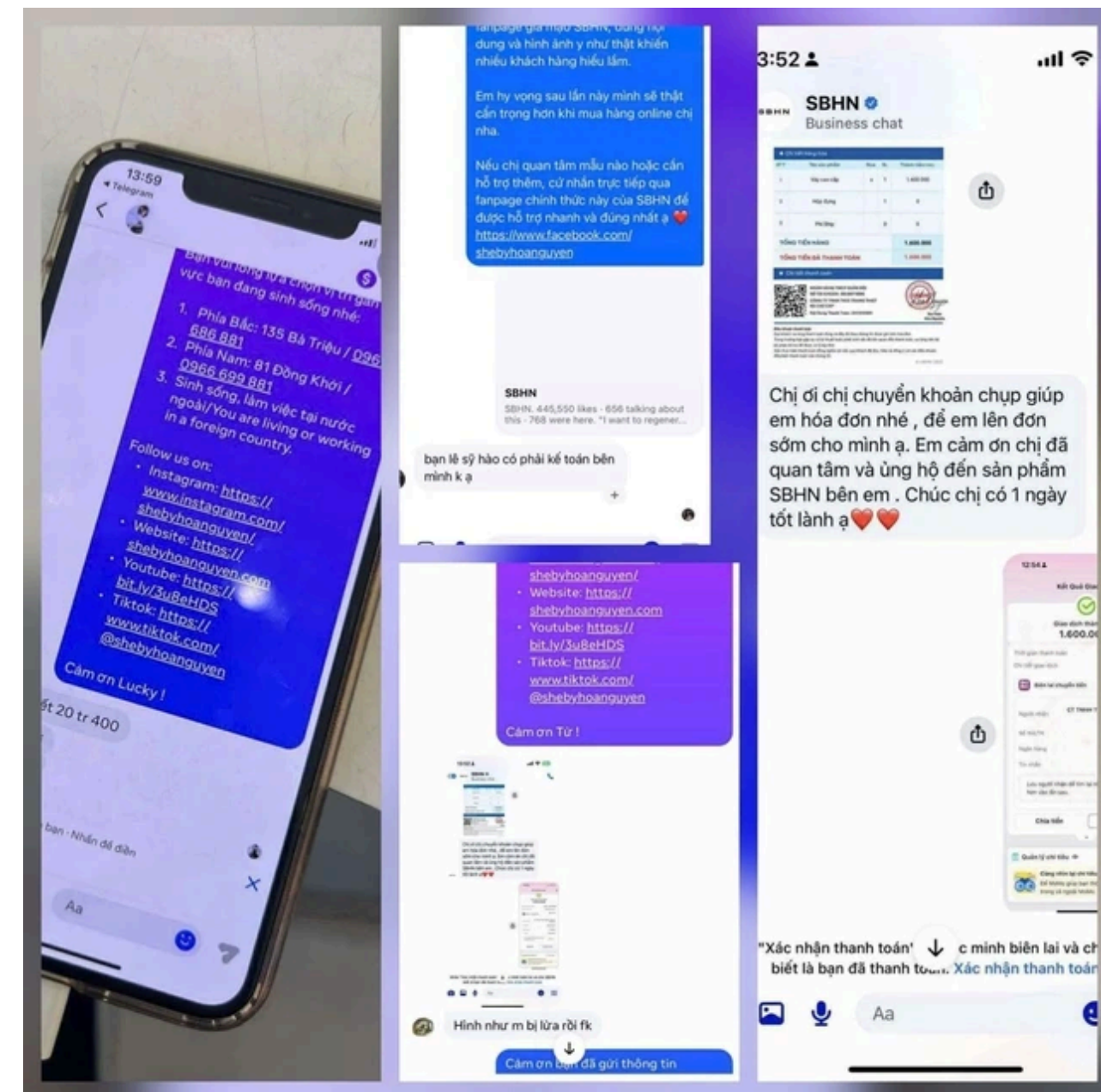
Thiệt hại

Khách: hàng chục người; 1 ca >20 triệu

DN: CSKH quá tải xác minh mỗi ngày

khách quen mất niềm tin kênh chính

phải chi thêm ngân sách đính chính



Nguồn: thanhnien.vn

**Luật Bảo vệ dữ liệu cá nhân
91/2025/QH15
(hiệu lực 01/01/2026)**

- Xin đồng ý khi thu thập dữ liệu
- Xử lý yêu cầu xóa dữ liệu trong thời hạn quy định
- Phạt có thể tới 5% doanh thu năm
- Học viên < 16 tuổi: cần đồng ý của phụ huynh

**Luật An ninh mạng 2025
(hiệu lực 01/07/2026)**

- Bảo vệ hệ thống & dữ liệu trên không gian mạng
- Nghĩa vụ bảo vệ trẻ em trên môi trường mạng
- The Forum có khóa Kid & Teenager → liên quan trực tiếp

**NĐ 131/2013/NĐ-CP (sđ NĐ
28/2017)+ Điều 225 BLHS**

- Phần mềm không bản quyền: rủi ro mã độc
- Chế tài hành chính; có thể xử lý hình sự (kể cả pháp nhân thương mại)

Sắp xếp theo thứ tự quan trọng từ cao xuống thấp

- | | |
|---|-------------------------------|
| 1. Email công ty/ Google Workspace | → Chìa khóa reset mọi dịch vụ |
| 2. CSDL học viên và phụ huynh | → PII: có dữ liệu trẻ em |
| 3. Fanpage-Tiktok-Youtube @theforumcenter | → Kênh tuyển sinh và uy tín |
| 4. Tài khoản ngân hàng + Hồ sơ học phí | → Dòng tiền |
| 5. Kho bài giảng/video khóa Online | → Tài sản trí tuệ |

Kiểm kê theo 3 bước: Liệt kê - Phân loại - Đánh giá

Phân loại rủi ro - mô hình 3 cấp

Rủi ro từ con người

- Giả mạo trung tâm qua email(Phishing) thu học phí
- Nhân viên chưa có kịch bản xác minh ngoài kênh
- Nhân sự nghỉ - Quyền chưa được thu hồi

Rủi ro kỹ thuật

- Tài khoản quản trị (admin) chưa bật xác thực đa yếu tố (MFA)
- Ransomware, phần mềm độc hại lây qua Drive Sync
- Wifi các cơ sở dùng chung/phần mềm không bản quyền

Rủi ro quy trình và tuân thủ

- Chưa có luồng đồng ý cho học viên dưới 16 tuổi
- Chưa bắt buộc xác minh khi đổi số tài khoản
- Backup chưa từng test khôi phục

Con người

1. Giả mạo trung tâm thu học phí

- Hậu quả: Phụ huynh mất tiền Trung tâm mất uy tín
- KRI: Số Fanpage/Zalo giả phát hiện & xử lý $\leq 48h$

2. Tư vấn viên chưa xác minh ngoài kênh

- Hậu quả: Nhận yêu cầu đổi STK qua tin nhắn $\rightarrow$ chuyển nhầm
- KRI: % nhân viên hoàn thành đào tạo ATTT = 100%

3. Giáo viên / nhân sự thời vụ nghỉ chưa thu hồi quyền

- Hậu quả: Còn vào Drive, nhóm Zalo học viên
- KRI: Số tài khoản “mồ côi” = 0

Kỹ thuật công nghệ

1. Tài khoản quản trị chỉ có mật khẩu

- Hậu quả: Mất Fanpage/email = mất kênh tuyển sinh
- KRI: % tài khoản trọng yếu đã MFA = 100%

2. Ransomware qua Drive Sync

- Hậu quả: File mã hóa đồng bộ lên cloud → “backup” cũng hỏng
- KRI: Có ≥ 1 bản sao lưu offline / offsite

3. 9 cơ sở: WiFi khách chung mạng nội bộ; máy dạy còn phần mềm không bản quyền

- Hậu quả: Học viên cùng mạng với máy nội bộ; rủi ro mã độc + pháp lý
- KRI: Số cơ sở đã tách WiFi khách = 9/9

Quy trình và tuân thủ

1. Dữ liệu học viên < 16 tuổi

- Hậu quả: Thiếu đồng ý phụ huynh → rủi ro Luật BVĐLCN 91/2025
- KRI: 100% hồ sơ Kid/Teen có mục đồng ý phụ huynh

2. Đổi số tài khoản nhận học phí

- Hậu quả: Không gọi lại xác minh → chuyển tiền cho kẻ giả mạo
- KRI: 100% giao dịch đổi STK có xác minh ngoài kênh

3. Sao lưu chưa từng kiểm tra khôi phục

- Hậu quả: “Có backup” ≠ “khôi phục được”
- KRI: 1 lần test restore / tháng, có ký xác nhận

HOẠT ĐỘNG CẢI TIẾN – GIẢI PHÁP NÂNG CAO AN TOÀN THÔNG TIN

THE
FORUM

Khóa công danh tính: MFA + thu hồi quyền



Hiện trạng và vấn đề rủi ro

- Email, Fanpage, TikTok, ngân hàng chủ yếu chỉ có mật khẩu
- Nhân sự nghỉ nhưng quyền truy cập chưa thu hồi kịp
- Liên quan: Con người, kỹ thuật



Hoạt động cải tiến và kết quả

- Bật MFA cho email, Fanpage, TikTok, ngân hàng
- Lập danh sách quản trị viên; gỡ tài khoản không còn dùng
- Quy tắc: nghỉ việc → vô hiệu hóa trong 24h
(Disable trước, Delete sau)

Kết quả đo được:

- ✓ 100% tài khoản trọng yếu có MFA
- ✓ 0 tài khoản mồ côi
- Chi phí: gần 0 • Thời gian: 1-2 tuần

HOẠT ĐỘNG CẢI TIẾN – GIẢI PHÁP NÂNG CAO AN TOÀN THÔNG TIN

THE
FORUM

*Chặn giả mạo thu học phí
(Xác thực ngoài kênh + công bố kênh chính thức)*



Hiện trạng và vấn đề rủi ro

- Phụ huynh khó phân biệt kênh thật / kênh giả
- Chưa có quy trình bắt buộc khi đổi số tài khoản
- Liên quan: Con người, quy trình



Hoạt động cải tiến và kết quả

- Công bố DUY NHẤT 1 số TK trên website + tại quầy
 - Cam kết công khai:
“Trung tâm không thu học phí qua tin nhắn riêng”
 - Đổi STK → phải gọi lại số nội bộ đã biết trước (OOB)
 - Tách hoặc phân quyền: người tạo lệnh / người duyệt / người chuyển tiền
- Kết quả đo được:**
✓ 100% giao dịch đổi STK được xác minh ngoài kênh
Chi phí: gần 0 • Thời gian: tuần đầu Tháng 1

HOẠT ĐỘNG CẢI TIẾN – GIẢI PHÁP NÂNG CAO AN TOÀN THÔNG TIN

THE
FORUM

*Bảo vệ dữ liệu học viên & tuân thủ
(Chia sẻ có kiểm soát + consent + AI an toàn)*



Hiện trạng và vấn đề rủi ro

- Danh sách học viên dễ chia sẻ dạng “ai có link cũng xem”
- Chưa có luồng đồng ý rõ cho học viên < 16 tuổi
- Nguy cơ dán PII vào AI công cộng khi chấm bài / telesales
- Liên quan: Quy trình



Hoạt động cải tiến và kết quả

- Drive: chia sẻ “người cụ thể” + đặt hạn truy cập
- Hợp đồng nhập học: thêm mục đồng ý phụ huynh (Kid/Teen)
- Quy tắc AI: che tên, SĐT trước khi hỏi
→ Mask → Prompt → Điền lại

Kết quả đo được:

- ✓ 0 file danh sách học viên ở chế độ công khai
- ✓ 100% hồ sơ < 16 tuổi có đồng ý phụ huynh
- Chi phí: gần 0 • Tuân thủ trước hiệu lực Luật 01/2026

HOẠT ĐỘNG CẢI TIẾN – GIẢI PHÁP NÂNG CAO AN TOÀN THÔNG TIN

THE
FORUM

Sao lưu 3-2-1 + Lộ trình 90 ngày



Hiện trạng và vấn đề rủi ro

- Dữ liệu chủ yếu trên cloud đồng bộ
- Chưa có bản offline / offsite tách biệt
- Chưa từng test khôi phục (P1, T1)



Hoạt động cải tiến và kết quả

- 3 bản sao • 2 loại phương tiện • 1 bản offline
- Test restore 3–5 file / tháng, mở trên máy khác, ký xác nhận
- LỘ TRÌNH 90 NGÀY**
- Tháng 1 – MFA • thu hồi quyền • công bố STK chính thức
- Tháng 2 – Tách WiFi khách 9 cơ sở • dựng backup 3-2-1
- Tháng 3 – Test restore • quy tắc AI • diễn tập sự cố
- Phù hợp SME không có IT chuyên trách • chi phí thấp



Kịch bản

Fanpage bị chiếm — đăng bài thu học phí giả

0–5 phút

- Báo quản lý / người phụ trách IT
- Không tự xử lý một mình · Không xóa bằng chứng

5–15 phút

- Thu hồi quyền · Đổi mật khẩu · Gỡ admin lạ
- Chụp màn hình giữ bằng chứng

15–30 phút

- Cảnh báo phụ huynh qua KÊNH PHỤ (website · hotline · Zalo lớp · email)
- Vì kênh chính đã mất kiểm soát

Sau 30 phút

- Liên hệ ngân hàng nếu đã có phụ huynh chuyển tiền
- Rà soát nguyên nhân → cập nhật quy trình

NGUYÊN TẮC

Không hoảng · Không tự sửa · Không trả tiền chuộc · Không xóa bằng chứng

TRÂN TRỌNG CẢM ƠN!